

MODULE 1.3

Security Policies, Regulations & Standards

Network Defense | Cisco Networking Academy

Prepared by: Kudzaishe Majeza

Cybersecurity Essentials

Topics Covered:

- 1.3.1 Business Policies
- 1.3.2 Security Policy
- 1.3.3 BYOD Policies
- 1.3.4 Regulatory and Standards Compliance

1.3.1 Business Policies

The foundation of all organizational security decisions

What are Business Policies?

- Documented rules and guidelines that govern how an organization operates
- Define expected behavior for all employees and staff
- Cover areas such as HR, finance, IT and security
- Serve as the foundation for all security controls
- Must be communicated clearly to all staff
- Require regular review and updates to stay relevant

Types of Business Policies

Company Policies

Rules covering employee conduct, HR, and workplace behavior

Employee Policies

Acceptable use of company resources and communications

Security Policies

Rules protecting information assets and systems

IT Policies

Standards for technology use, access and procurement

1.3.2 Security Policy

A formal set of rules to protect the organization's information and systems

What is a Security Policy?

- A formal, documented set of rules that everyone in the organization must follow
- Defines what is permitted and what is prohibited
- Must be approved and enforced by management
- Covers all aspects of information security
- Requires regular review and updates
- All employees must read, understand and sign it

Key Components of a Security Policy

- Identification & Authentication Policy — who can access systems and how they prove identity
- Password Policy — minimum length, complexity and expiry requirements
- Acceptable Use Policy (AUP) — how employees may use company systems and the internet
- Network Access Policy — rules for connecting to the network including remote access
- Incident Response Policy — steps to follow when a security incident occurs
- Data Handling Policy — how sensitive data must be stored, shared and disposed of

1.3.3 BYOD Policies

Managing the risks of employees using personal devices for work

What is BYOD?

- BYOD = Bring Your Own Device
- Employees use personal phones, tablets or laptops for work purposes
- Increases flexibility and productivity
- Reduces hardware costs for the organization
- Introduces significant security risks if not properly managed
- Requires a clear, enforced BYOD policy

BYOD Security Risks

- Data leakage — sensitive data on unmanaged personal devices
- Lost or stolen devices exposing company information
- Malware from personal apps infecting the corporate network
- Mixing personal and work data on the same device
- Employees leaving and taking data with them
- Connecting to unsecured public Wi-Fi networks

What a BYOD Policy Should Cover

- Which devices and OS versions are permitted
- Mandatory security software and encryption requirements
- Separation of work and personal data
- Remote wipe capability if device is lost or stolen
- MDM (Mobile Device Management) tool enrollment
- What happens to data when an employee leaves

1.3.4 Regulatory and Standards Compliance

Meeting legal requirements and industry standards for information security

Key Regulations

GDPR

General Data Protection Regulation — protects personal data of EU citizens

HIPAA

Health Insurance Portability & Accountability Act — protects health data

PCI-DSS

Payment Card Industry Data Security Standard — protects card payment data

SOX

Sarbanes-Oxley Act — financial reporting and IT controls for public companies

POPIA

Protection of Personal Information Act — South Africa's data protection law

Key Standards

- ISO/IEC 27001 — international standard for information security management systems
- NIST Cybersecurity Framework — guidelines for managing cybersecurity risk (US-based)
- CIS Controls — prioritized set of actions to defend against known cyber threats
- COBIT — framework for IT governance and management aligned to business goals

- Non-compliance consequences:
- Heavy financial fines and penalties
- Legal action and loss of operating licenses
- Reputational damage and loss of customer trust

Key Takeaways

Module 1.3: Security Policies, Regulations & Standards | Cisco Networking Academy



Business policies set the rules for all organizational behavior and are the foundation of security.



A security policy defines what is permitted, what is prohibited, and how incidents are handled.



BYOD introduces real risks — lost devices, data leakage and malware — and requires a strict policy.



MDM tools help enforce BYOD security including remote wipe, encryption and data separation.



Compliance with regulations (GDPR, HIPAA, PCI-DSS) and standards (ISO 27001, NIST) is mandatory.



Non-compliance results in fines, legal action and serious reputational damage.